ISTQB® Certified Tester
Advanced Level — **Security Tester** (CT-SEC, Syllabus 2016)

CHAPTER 5
Testing Security Mechanisms

Complete Study Guide

Chapter fact	Value
Syllabus sections covered	5.1 System Hardening · 5.2 Authentication and Authorization · 5.3 Encryption · 5.4 Firewalls and Network Zones · 5.5 Intrusion Detection · 5.6 Malware Scanning · 5.7 Data Obfuscation · 5.8 Training
Learning objectives	16 examinable (AS-5.1.1 – AS-5.8.2) · K2 = 8 · K3 = 8 — one “understand” and one “test” objective per mechanism
Recommended teaching time	240 minutes — **the longest chapter** — **12 points**, 3.0 points per teaching hour
Questions in the exam	**8 of 45 questions · 12 of 80 points. K2 = 4** (drawn from the 8 K2 objectives) · **K3 = 4** (drawn from the 8 K3 objectives). In the Sample Exam each mechanism appeared once
Exam format	45 questions · **80 points** · **120 minutes** (150 with the 25% non-native-language allowance) · pass mark 65% = **52 points** · K2 = 1 pt · K3 = 2 pts · K4 = 3 pts
Keywords	anti-malware · authentication · authorization · demilitarized zone · encryption · firewall · hashing · insider threat · intrusion detection system · malware · malware scanning · network zone · pharming · phishing · salting · system hardening · vulnerability scanner
Official sample-exam questions	**#25 – #32** (2 + 1 + 2 + 1 + 2 + 1 + 2 + 1 points)

Built exclusively from the ISTQB® Advanced Level Security Tester syllabus (2016), the official Sample Exam (questions and answers, GA March 2016) and the ISTQB® exam structure tables.

Study this single file to master Chapter 5.

Contents

Section 1 — Syllabus Explanation 4
Chapter framing — mechanisms are layers, not solutions 4
AS-5.1.1 (K2) — Understanding System Hardening 5
AS-5.1.2 (K3) — Testing the Effectiveness of System Hardening 5
AS-5.2.1 (K2) — Authentication and Authorization 6
AS-5.2.2 (K3) — Testing Authentication and Authorization 7
AS-5.3.1 (K2) — Understanding Encryption 7
AS-5.3.2 (K3) — Testing Common Encryption Mechanisms 7
AS-5.4.1 (K2) — Understanding Firewalls and Network Zones 8
AS-5.4.2 (K3) — Testing Firewall Effectiveness 9
AS-5.5.1 (K2) — Understanding Intrusion Detection Tools 9
AS-5.5.2 (K3) — Testing Intrusion Detection Tools 10
AS-5.6.1 (K2) — Understanding Malware Scanning Tools 10
AS-5.6.2 (K3) — Testing Malware Scanning Tools 11
AS-5.7.1 (K2) — Understanding Data Obfuscation 11
AS-5.7.2 (K3) — Testing Data Obfuscation Approaches 12
AS-5.8.1 (K2) — The Importance of Security Training 12
AS-5.8.2 (K3) — Testing the Effectiveness of Security Training 12
Section 2 — Key Concepts 14
2.1 One line per mechanism 14
2.2 Chapter 5 keyword glossary 14
Section 3 — Tables and Summaries 16
Section 4 — Demo Questions with Answers 17
Part A — The 8 official Chapter 5 questions 17
Part B — 24 additional syllabus-derived questions 19
Most Important Questions From This Chapter 25
Section 5 — Exam Tricks 27
5.1 Frequently tested topics (evidence-based) 27
5.2 Common distractors observed 27
5.3 Keyword recognition (map words → answers) 27
5.4 Typical traps 28
5.5 How to eliminate wrong answers 28
5.6 Scenario-solving shortcuts 28
5.7 Common candidate mistakes 29
5.8 Mnemonics that carry the whole chapter 29
5.9 Chapter 5 mind map 29
Section 6 — Flashcards 30
Section 7 — Revision Notes 33
7.1 One-page chapter summary 33
7.2 Key definitions to memorize 33
7.3 High-priority concepts (study first) 33
7.4 Last-minute revision sheet 33
7.5 Memorization checklist 34
7.6 Exam-day quick review 34

In Word, right-click the table of contents and choose "Update Field" → "Update entire table" to refresh the page numbers.

How to use this guide

Section 1 walks the eight mechanisms, each with its K2 concept and K3 effectiveness test — read it once. **Section 2** puts each mechanism on one row. **Section 3**, **table 3.1 (mechanism → weakness → test)**, is the single most useful table in this guide. **Section 4** is the question bank, **Section 5** exam tactics, **Section 6** spaced repetition, **Section 7** the night before.

What makes Chapter 5 unusual: it is the **longest chapter (240 minutes)** for only **12 points — 3.0 points per hour**, the joint-lowest return. Sixteen objectives feed eight questions, so on any paper about half of the content is not examined. **Breadth beats depth here.**

The rule that decides it: for every mechanism, **know the weakness the syllabus names, because the test exploits it** — anti-malware only knows the known (EICAR, pilot first), signature IDS misses the unknown (evasion), behaviour IDS drifts (feed it malicious traffic), obfuscation is reversible (brute force, decompilers), humans are the weakest link (social engineering, sticky notes).

Suggested schedule: Day 1 — §5.1–5.4. Day 2 — §5.5–5.8 and Section 3. Day 3 — Section 4 and Section 5. Day 4 onwards — Section 6 daily, Section 7 the night before.

Section 1 — Syllabus Explanation

Chapter 5, **Testing Security Mechanisms**, covers **eight mechanisms** — system hardening, authentication and authorization, encryption, firewalls and network zones, intrusion detection, malware scanning, data obfuscation, and training — each with a **K2 "understand" objective** and a **K3 "test the effectiveness" objective**: **16 learning objectives** in all. The Exam Structure Table allocates **8 questions** and **12 of the 80 points**.

Teaching time is **240 minutes — the longest chapter in the syllabus** — for **3.0 points per teaching hour**, the joint-lowest return. The questions are drawn as **four K2 (1 point) from the eight "understand" objectives** and **four K3 (2 points) from the eight "test" objectives**. In the official Sample Exam, **each mechanism appeared exactly once**, alternating K3 and K2 (Q25 to Q32). Learn every mechanism to the same depth, but **do not over-invest**: the content is broad and the marks are thin.

Mechanism	K2 — understand	K3 — test effectiveness	Sample #
5.1 System hardening	AS-5.1.1	AS-5.1.2	#25 (K3, 2 pts)
5.2 Authentication and authorization	AS-5.2.1	AS-5.2.2	#26 (K2, 1 pt)
5.3 Encryption	AS-5.3.1	AS-5.3.2	#27 (K3, 2 pts)
5.4 Firewalls and network zones	AS-5.4.1	AS-5.4.2	#28 (K2, 1 pt)
5.5 Intrusion detection	AS-5.5.1	AS-5.5.2	#29 (K3, 2 pts)
5.6 Malware scanning	AS-5.6.1	AS-5.6.2	#30 (K2, 1 pt)
5.7 Data obfuscation	AS-5.7.1	AS-5.7.2	#31 (K3, 2 pts)
5.8 Training	AS-5.8.1	AS-5.8.2	#32 (K2, 1 pt)
Chapter 5 total	**4 questions × 1**	**4 questions × 2**	**8 questions · 12 points**

Exam allocation you must know

Chapter 5 = **8 questions / 12 points** from **16 objectives**; Sample Exam **#25 to #32**. Every K3 objective has the same verb — **"demonstrate how to test the effectiveness of ..."** — and every K2 has the same shape — **"understand the concept of ... and how it is applied"**. A K3 question usually offers **one test technique the syllabus names for that mechanism** among three plausible activities that are not tests of it.

The one thing that decides this chapter

For each mechanism, know its weakness — the test exploits the weakness. Hardening: defaults and unnecessary services → **audit configuration, run a vulnerability scanner**. Authentication: weak passwords and unfiltered input → **brute force, dictionary, injection, URL/URI tampering**. Encryption: small keys, wrong modes, bad randomness, weak configuration → **key size, modes, certificates, code review, TLS configuration**. Firewalls: complexity → **port scanning, malformed packets, fragmentation**. IDS: signatures miss the unknown, behaviour drifts → **evasion encodings, malicious traffic to poison the profile**. Anti-malware: **only knows what it knows → EICAR**, test before deploying. Obfuscation: reversible → **brute force, decompilers**. Training: humans → **social engineering, sticky notes, password audits**.

Chapter framing — mechanisms are layers, not solutions

Each mechanism can be applied through **tools and infrastructure** or **manual effort**. **None of these mechanisms alone is sufficient in most cases** to secure information; **each has its own advantages and disadvantages**. Testers need to understand **the nuances of each line of defense** to design tests that **verify and validate their effectiveness**, and advanced testers should **design a test architecture that provides a framework for continuous security testing**.

AS-5.1.1 (K2) — Understanding System Hardening

Original syllabus statement

Understand the concept of system hardening and its role in enhancing security.

Systems grow more complex, so **their attack surface is continuously growing**. Vulnerabilities come from three sources:

Source	Syllabus term	Example
Design errors	**By design** vulnerabilities	Missing authorization layer
Source code defects	**By construction** vulnerabilities	Buffer overflow
Lack of rigor in configuration	**By configuration** vulnerabilities	Default passwords, open ports

System hardening is the step-by-step process of reducing the attack surface by applying a security policy and different layers of protection. The main objective is to secure the system and reduce the risks of compromising security. It can be applied to **a component, a product/application, a system, or a system of systems**.

Organizational and technical defenses to apply

Defense	Why (syllabus)
Remove unnecessary **software**	Can contain defects
Remove unnecessary **libraries and developer tools**	Can contain defects
Remove unnecessary **accounts/logins**	Attack vectors
Remove unnecessary **applications and network services**	Defects; attack vectors
Remove unnecessary **peripherals and hardware ports** (USB, card readers)	—
Promptly patch and install updates (e.g. **automatic updates**)	—
Update configurations	—
Follow coding rules	Avoid **by-construction** vulnerabilities
Configure a remote logging server (e.g. **rsyslog**)	An attacker can delete logs **only on the compromised machine, not on the remote log server**

Security mechanisms that hardening should use: strong authentication and efficient **authorization** (only the rights needed, by role) · **encryption** (communication and local storage) · **firewalls** (personal, system, web application) and **security zones** (e.g. a **sandbox**) · **IDS** · **anti-malware/anti-spyware** · **obfuscation** of data and applications (against reverse-engineering).

The balance

Rules must be applied **at the right level and balanced with usability**. **At the extreme, protections are disabled because they block the productivity of the company** — over-hardening defeats itself.

AS-5.1.2 (K3) — Testing the Effectiveness of System Hardening

Original syllabus statement

Demonstrate how to test the effectiveness of common system hardening mechanisms.

Tests depend on **the nature of the system, the sensitivity of assets and the identified threats**. Hardening **restricts access to the right roles, opens only needed services, and monitors application updates** — so tests should show hardening is **working, applied in the right places, and applied in the right ways**. **Also test for protections that are too restrictive** and excessive in view of the risks.

- Some tests are **review- or audit-based**; others test **the ability of user groups to perform actions or access data**.
- **Audit database and application server configuration** to verify **default passwords have been changed**.
- **Audit system configuration** to identify **unnecessary services and network ports**.
- **Verify components, libraries and application versions** are **not obsolete and vulnerable**.
- Run a **vulnerability scanner** to ease vulnerability assessment, especially in **complex (e.g. multi-site)** systems.
- Use **static analysis tools** to detect **violations of coding rules** (construction vulnerabilities); **security-oriented analyzers** are particularly useful.

How the official exam used this objective (K3, 2 points)

Sample Q25: procedure to ensure hardening mechanisms work as expected? **Closely monitor security performance reports and metrics to determine if the correct level of access and authentication is achieved.** Rejected: auditing **strong authentication** (just **one aspect** of hardening); seeking **equilibrium** between hardened components (not needed — **more critical areas may warrant better hardening**); enlisting **a known hacker** (**the danger of the hacker not telling you what is found**).

AS-5.2.1 (K2) — Authentication and Authorization

Original syllabus statement

Understand the relationship between authentication and authorization and how they are applied in securing information systems.

	Authentication	Authorization
Question answered	**Login: who is the user? Password: is the user really who he pretends to be?**	**Does the authenticated user have the rights to do this action?** Which **level of access** to resources?
Based on	Verification of **a user identifier and a token**	Rights assigned to the authenticated identity
Implementations	Detecting **weak passwords · one-time passwords (OTP) · fingerprinting · software certificates · certificates in hard tokens**	e.g. can log into a server **but not modify its data**; FTP use **only in a dedicated space**
Architectures	**Local · server · network authentication · Single Sign-On (SSO)**	Role-based levels

The link: a non-authenticated user has no rights or restricted rights (not authorized to manipulate sensitive data). Merchant site example: an anonymous user **can see the product list**; to buy, they **create an account**; the authenticated user **can purchase but cannot perform administrative functions**.

How the official exam used this objective (K2, 1 point)

Sample Q26: key attribute of **authentication**? **It verifies that the user entering the system is legitimate.** Rejected: **correct profile and rights to limited parts** (that is authorization — **not looking at access rights**); **system resources** (not a consideration); **common credentials** (**each individual should have unique credentials**).

AS-5.2.2 (K3) — Testing Authentication and Authorization

> **Original syllabus statement**
> Demonstrate how to test the effectiveness of common authentication and authorization mechanisms.

Attackers aim **to steal passwords or bypass systems** to execute unauthorized actions, exploiting **coding errors (lack of input filtering) · old vulnerable library versions · configuration errors (default passwords, default rights) · weak passwords** (the most used is **"123456"**). Password rules **don't help if users aren't diligent**, and must reflect **current good practice** (e.g. **SANS Password Construction Guidelines**).

Tests for authentication and authorization

Test	Example
Brute force and dictionary attacks	Try **"123456", "111111", date of birth, name of pet**…
Exploit lack of input filtering	**Inject SQL** to be **authenticated without any known login/password**
Unauthorized URI / URL	**../../** in an FTP account; **site address/admin** to reach sensitive data
Exploit an unpatched vulnerability	Cause unintended behavior → **gain control** → **privilege escalation**

AS-5.3.1 (K2) — Understanding Encryption

> **Original syllabus statement**
> Understand the concept of encryption and how it is applied in securing information systems.

Encryption is a process of encoding data (plain text) into cypher data (cypher text), using a cryptographic algorithm and secrets, so that only authorized persons can access it by using a decryption mechanism. The secret is **shared and only known to authorized users**. Goal: strong enough that an attacker **who has stolen encrypted data cannot recover the plain text**. **Hashing and salting are methods used during encryption.**

Protects data…	Examples
Stored in a system	**Cyphered passwords in a database**, logical cyphered drive, **whole cyphered hard drive**
During communication	**Cyphered email**, cyphered protocols (**SSL, TLS**)

Protocol family	Key model
Symmetric encryption	**Shared secret key**
Asymmetric encryption	**Private and public key**

*The syllabus says cryptography helps ensure confidentiality, integrity, availability of sensitive assets "and repudiation of manipulating them" — read this as **non-repudiation**.*

AS-5.3.2 (K3) — Testing Common Encryption Mechanisms

> **Original syllabus statement**
> Demonstrate how to test the effectiveness of common encryption mechanisms.

Some mechanisms are **weak because of short or static keys**; others because they are **not implemented with best practices** or **embed coding defects** (e.g. buffer overflow). Tests fall into **three families plus ageing** — the same design / construction / configuration split as hardening:

Family	Tests
Design vulnerabilities	**Right modes used in symmetric encryption · key size not too small** (as of 2015, **RSA under 2048 bits is insecure**) · **certificate validity** and **alerts on self-signed certificates** (**SSL-trip** can be used to avoid man-in-the-middle) · **replay attacks** (e.g. against **WEP**) · **attacks on cryptographic protocols** to verify strength [Bittau]
Construction vulnerabilities	**Code reviews** — e.g. verify the **default random() is not used** to seed (relatively easy to crack) · **fuzzing** · **timing attacks** (time taken by crypto algorithms) · **power analysis** (encrypted hardware devices)
Configuration vulnerabilities	**Protocol configuration assessment** (TLS server-side, client-side authorized protocols, per a TLS configuration guide) · **TLS cipher order on the server** — can the cipher be **downgraded or renegotiated**?
Ageing	Verify mechanisms that **may have become weak and prone to being cracked**

How the official exam used this objective (K3, 2 points)

Sample Q27: what to implement to gain confidence in encryption? **Develop tests that ensure symmetric encryption is used in the right modes** — per the syllabus. Rejected: "keys **at least 256 bits**"; "**apply random algorithms** to generate random numbers" (**random() is easy to crack**); "**remove all WEP protocols** to see how the system performs" (the rationale says WEP should be **left in place**, not removed). Note: the official rationale for (a) says "**a minimum of 768 bits should be used**", which does not match the syllabus's **2048-bit RSA** statement — answer from the syllabus.

AS-5.4.1 (K2) — Understanding Firewalls and Network Zones

Original syllabus statement

Understand the concept of firewalls and the use of network zones and how they are applied in securing information systems.

"A firewall is a component or a set of components that restricts access between a protected network and the Internet, or between other sets of networks" [Chapman 2000]. It **implements and enforces a security policy** based on **authorized and forbidden communications**. It may be **host-based** (software on one host monitoring application inputs/outputs) or **network-based** (software monitoring traffic between networks). Its main task: **control traffic between trusted zones by filtering data**, so **malicious traffic from an untrusted zone is detected and blocked**.

Network zones — a sub-network with a defined level of trust

Zone	Trust
Internet / public zone	**Untrusted**
Demilitarized zones (DMZs) — several possible	**Different levels of trust**
Private / internal networks	**Most trusted**

Zones are part of the firewall configuration: they define **the authorized flows between networks**; **all forbidden traffic is blocked**.

Firewall filters on...	A WAF also filters on...
Source and target addresses and protocols (Ethernet/IP addresses, TCP/UDP ports)	**Users being the connections**

Firewall filters on...	A WAF also filters on...
Protocol options (fragmentation, TTL)	**Data filtering** (e.g. **pattern descriptions**)
Size of data	

How the official exam used this objective (K2, 1 point)

Sample Q28: relationship between a firewall and a network zone? **A sub-network can be considered a network zone and a firewall can be traffic monitoring software.** Rejected: both focus on **size of data** (zones don't); zones **communicate through safe protocols** (zones are **part of the firewall configuration** defining authorized flows); **the zone blocks** traffic (**the firewall blocks**, not the zone).

AS-5.4.2 (K3) — Testing Firewall Effectiveness

Original syllabus statement

Demonstrate how to test the effectiveness of existing firewall implementations and network zones.

Because of **the number of protocols, their options and network complexity**, **it is difficult to configure a firewall efficiently**. Tests should include:

Test	Purpose
Port scanning	Verify **the security policy is well implemented**
Malformed network packets and network fuzzing	Exploit **unexpected behavior** — e.g. a **denial of service**
Fragmentation attacks	**Bypass filtering** to carry the attack **behind the firewall**
WAF: encode, compress or obfuscate data	**Hide the malicious information** conveying the attack

*Chapter 8's official Q42 (3 points) is a firewall scenario: after configuration checks and port scanning, the test that detects unexpected behaviour exploitable by DoS is **malformed packets or fuzzed data**.*

AS-5.5.1 (K2) — Understanding Intrusion Detection Tools

Original syllabus statement

Understand the concept of intrusion detection tools and how they are applied in securing information systems.

Attacks increase every year, techniques evolve quickly and no system is 100% safe. An **IDS** is **a standalone appliance or application** that **monitors activities at different levels — network to application, the 7 layers of the OSI model — to detect violations of the security policy**. Deviations from normal behavior raise **alerts** for further action (**traffic blocking, virtual patching**).

Two security models (IETF Intrusion Detection Exchange Format working group)

	Negative security model	Positive security model
Also called	**Signature-based / blacklist** detection	**Behavior-based / white list** detection
Rule	**"All that is not explicitly forbidden is allowed"**	**"All that is not explicitly allowed is rejected"**
Detects by	A **list of known attacks or patterns**	**Specification of expected behavior** — e.g. an input's characteristics as a **regular expression**; **trusted traffic**

	Negative security model	Positive security model
		may generate the specification
Weakness	**Easy to bypass — only known attacks are detected**	**Large numbers of false positives and false negatives**; behaviour can be **deviated** so intrusive traffic becomes "normal"

Firewall vs IDS

A firewall looks outwardly at the traffic to stop intrusions; an IDS analyzes suspicious intrusions and raises an alert if they are confirmed.

AS-5.5.2 (K3) — Testing Intrusion Detection Tools

Original syllabus statement

Demonstrate how to test the effectiveness of existing intrusion detection tool implementations.

Target	Tests
Signature/scenario-based detection	**Evasion techniques: character encoding or modification** (white space, end of lines) · **IP fragmentation, TCP segmentation · encryption, obfuscation · URL encoding**
Behavior-based detection	Check **false negatives** (alerts that should have been reported but weren't — e.g. **new attacks**, or **rules that catch some attacks and miss others**) and **accuracy**. Because an attacker can **deviate the learned behavior** until intrusive traffic is "normal", **complementary tests should use malicious traffic in order to add new intrusive specifications considered as authorized traffic**
Test inputs	**Protection Profile for IDS** [PP-IDS] · **Web Application Firewall Evaluation Criteria** [WAFEC]

How the official exam used this objective (K3, 2 points)

Sample Q29: most effective test of an IDS? **Use tests that generate malicious traffic to add new intrusive specifications** — they target specifications **formerly considered authorized traffic**. Scenarios from past experience and known malicious traffic **might be useful but are less effective for the future**; combining IDS products is **true for usage, not for testing**.

AS-5.6.1 (K2) — Understanding Malware Scanning Tools

Original syllabus statement

Understand the concept of malware scanning tools and how they are applied in securing information systems.

- Malicious code reaches servers and end-user machines via **email attachments, fake URLs, client-side code execution**, etc.
- **Anti-malware** analyzes, detects and removes malicious code; detection targets: **malware, phishing and pharming**.
- **Main detection = signature-based**: search a database for **known patterns**. **New malware, or malware whose signature is not in the database, will not be detected.**
- A **heuristic mechanism** is often embedded to identify **slight variations of known patterns**.

How the official exam used this objective (K2, 1 point)

Sample Q30: main disadvantage of malware scanning tools? **They can only detect malware that is known to the tool.** Rejected: "only certain levels" (depends on focus, not the main disadvantage), "overly complex to run" (generally **easy to run**), "no updating or reporting" (they **do** update and report). (The official rationale mislabels the first rejection as "B"; the reasoning refers to option a.)

AS-5.6.2 (K3) — Testing Malware Scanning Tools

Original syllabus statement

Demonstrate how to test the effectiveness of existing malware scanning tool implementations.

How malware evades analysis and detection

Technique	Example
Exploiting system library functions	**FindWindow** used to **close an anti-malware application**
String obfuscation	Encryption; **JavaScript stored in a PDF**; compression with **UPX** (Ultimate Packer for Executables)
Dynamic loading of functions and libraries	Limits analysis of the malicious code
Automatic update of applications	**Skype Trojan**
Using other hardware	**GPU** decompresses code into memory — **cannot be analyzed before execution**

- Functional test: **EICAR anti-malware test file** checks effectiveness **without developing real malicious code**.
- **Test a new or upgraded anti-malware implementation on a representative platform before deploying it organization-wide** — products have **falsely identified legitimate OS files as malware and quarantined them**, **shutting down the organization's entire computing capability**.

AS-5.7.1 (K2) — Understanding Data Obfuscation

Original syllabus statement

Understand the concept of data obfuscation tools and how they are applied in securing information systems.

Obfuscation (sometimes called data masking) makes data and source code non-understandable for a human. It protects sensitive data against **copying (to bypass licence protection)** and **reverse-engineering (to understand code and exploit vulnerabilities)**.

- Lets **support personnel, functional testers, etc.** work with **non-sensitive data** while **sensitive data is hidden** — also called **data anonymization** (keeps personal data anonymous).
- Protects **source code** against **copy-paste** (e.g. an innovative algorithm) and reuse after reverse-engineering.
- Optimizing code (e.g. **parts in assembly**) can incidentally obfuscate it.
- Protects **sensitive HTML pages** (connection, administration) against **script injection**, whose success depends on knowing the site's structure.
- **Techniques: base64-encoding · XORing · randomly renaming functions · methods overriding · tab-return-space deletion · shuffling**. **Encryption** is also obfuscation, **but cyphered data remains viewable to those with valid keys**.
- **Attackers also use obfuscation** to hide malicious code and attacks.

AS-5.7.2 (K3) — Testing Data Obfuscation Approaches

Original syllabus statement

Demonstrate how to test the effectiveness of data obfuscation approaches.

- **Tight configuration control between obfuscated data and keys** — otherwise data **cannot be un-obfuscated**.
- Obfuscation renders **production data used in a system test environment anonymous** — e.g. a **health information system** must not divulge patient data to testers.
- **Data tests: brute force or dictionary attacks** to try to get plain data from obfuscated data.
- **Code tests: reverse-engineer Java byte code** (e.g. **Java Decompiler**) or **.NET** (e.g. **.NET Reflector**); **brute force** on vulnerable mechanisms (e.g. **unXOR**).
- **In theory code cannot protect itself against de-obfuscation, because debugging can always be used**; anti-decompilation tools exist but **risks and limitations remain**.

How the official exam used this objective (K3, 2 points)

Sample Q31: removing personal identification numbers from a legacy system for testing — how to verify masking effectiveness? **Design a brute force attack on the obfuscated data.** Rejected: **manual inspection in the database** (not feasible for the volume of data and time); **substituting random data of varying lengths** (an anonymizing exercise, and field lengths may corrupt data); **stressing the database** (not the goal).

AS-5.8.1 (K2) — The Importance of Security Training

Original syllabus statement

Understand the concept of security training as a software lifecycle activity and why it is needed in securing information systems.

Humans are often the weakest link in the overall security picture. Hence **consistent and continuous training** to remind people **why policies matter** and to follow them. Training should occur **throughout the software lifecycle**, be **updated as new policies and threats arise**, and cover **identification of social engineering attacks and insider threats**.

How the official exam used this objective (K2, 1 point)

Sample Q32: weakest link in software security? **The behavior of humans.** The other options (no training plan, effort to maintain documents, advancing attack techniques) are concerns, **but people and their behavior are the weakest link**.

AS-5.8.2 (K3) — Testing the Effectiveness of Security Training

Original syllabus statement

Demonstrate how to test the effectiveness of security training.

Training topic	Effectiveness test	What a failure means
Strong, confidential passwords	**Social engineering** call from a **fake technical support person · look around desks for sticky notes** (especially **under keyboards**) · run **password audit tools** — risk: **passwords may be viewable to the person running the test**	Users need retraining
Secure coding	Tester **injects SQL** through a field with **no field-level edit**	**This developer needs training**; **check**

Training topic	Effectiveness test	What a failure means
	and sees the customer database	**other developers' code** — if widespread, a **general process improvement initiative** is needed
Physical security / clean desk	Tester attempts **unauthorized physical access** and **views documents left in the open**	Awareness and physical controls need reinforcement

Section 2 — Key Concepts

2.1 One line per mechanism

Mechanism	Concept (K2)	Test (K3)
Hardening	Step-by-step attack-surface reduction by policy and layers; remove, patch, configure, remote logs; balance usability	Audit defaults, services, ports, versions; vulnerability scanner; static analysis; check over-restriction
AuthN / AuthZ	AuthN = who and is it really you (ID + token); AuthZ = rights and access level; unauthenticated = no/restricted rights	Brute force, dictionary, SQL injection to bypass login, ../../ and /admin, exploit unpatched flaws
Encryption	Plain → cypher text with algorithm + secret; at rest and in transit; symmetric (shared key) vs asymmetric (public/private); hashing and salting	Modes, key size (RSA ≥ 2048), certificates/self-signed, replay; code review (random()), fuzzing, timing, power; TLS config and cipher order; ageing
Firewalls / zones	Restricts access between networks; host- or network-based; zones of trust (public, DMZ, internal); filters addresses, options, size; WAF filters users and data patterns	Port scanning, malformed packets and fuzzing, fragmentation; WAF: encode, compress, obfuscate
IDS	Monitors OSI layers for policy violations; negative (signature, blacklist) vs positive (behaviour, white list); IDS alerts, firewall blocks	Evasion (encoding, fragmentation, encryption, URL encoding); false negatives; malicious traffic to add intrusive specifications; PP-IDS, WAFEC
Anti-malware	Signature-based + heuristic; malware, phishing, pharming; misses the unknown	EICAR; test on a representative platform first; know evasion techniques (FindWindow, UPX, dynamic loading, GPU)
Obfuscation	Make data/code non-understandable; masking, anonymization; base64, XOR, renaming, shuffling; encryption with key caveat	Key/data configuration control; brute force/dictionary; decompilers; unXOR; code can't fully protect itself
Training	Humans weakest link; continuous, lifecycle-wide; social engineering and insider threats	Fake support call; sticky notes; password audit; SQLi by a tester; physical access attempt

2.2 Chapter 5 keyword glossary

Keyword	Working definition for the exam
anti-malware	Software to analyze, detect and remove malicious code; mainly signature-based plus heuristics.
authentication	Verifying a user identifier and token — who the user is and whether they are who they claim.
authorization	Verifying an authenticated user's rights to an action and level of access.
demilitarized zone	A network zone between untrusted and internal networks with an intermediate level of trust.
encryption	Encoding plain text into cypher text with an algorithm and secrets so only authorized persons can decrypt.
firewall	Component(s) restricting access between a protected network and the Internet or other networks.
hashing	A one-way transformation used during encryption (e.g. of stored passwords).
insider threat	A threat from an authorized user inside the organization.
intrusion detection system	Appliance or application monitoring activity to detect security-policy violations and raise alerts.
malware	Malicious code placed at a target via email, fake URLs, client-side execution, etc.
malware scanning	Detecting malware by known signatures and heuristics.

Keyword	Working definition for the exam
network zone	A sub-network with a defined level of trust.
pharming	Redirecting users to fraudulent sites; a detection target of anti-malware.
phishing	Luring users to reveal information or visit infected sites; a detection target of anti-malware.
salting	Adding random data before hashing, used during encryption to strengthen stored secrets.
system hardening	Step-by-step reduction of the attack surface by applying a security policy and layers of protection.
vulnerability scanner	A tool that eases vulnerability assessment, especially in complex systems.

Section 3 — Tables and Summaries

3.1 Mechanism → weakness → test (the K3 decider)

Mechanism	Weakness the syllabus names	Test the syllabus names
Hardening	Defaults, unnecessary services and ports, obsolete versions	Configuration audit; vulnerability scanner; static analysis
AuthN/AuthZ	Weak passwords, no input filtering, default rights, old libraries	Brute force/dictionary; SQLi; URI/URL tampering; exploit unpatched flaw
Encryption	Short/static keys, wrong modes, bad randomness, poor configuration, ageing	Key size; modes; certificates; code review; timing/power; TLS config; ageing
Firewall	Hard to configure efficiently	Port scan; malformed packets/fuzzing; fragmentation; WAF encoding
IDS	Signatures miss unknown attacks; behaviour models drift	Evasion encodings; malicious traffic to add intrusive specifications
Anti-malware	Only detects known malware; false positives can kill systems	EICAR; representative platform first
Obfuscation	Reversible; keys must match	Brute force/dictionary; decompilers; unXOR
Training	Humans	Social engineering call; desk sweep; password audit; SQLi; physical access

3.2 Design / construction / configuration — the recurring triad

Vulnerability type	Hardening example	Encryption example
By design	Wrong architecture	Wrong mode; small key; self-signed certificate; replayable protocol
By construction	Coding-rule violation (static analysis)	random() seed; fuzzing; timing; power analysis
By configuration	Default passwords; open ports	TLS configuration; cipher order downgrade

3.3 Negative vs positive security models

	Negative	Positive
Rule	Not forbidden → allowed	Not allowed → rejected
Also called	Signature / blacklist	Behaviour / white list
Fails by	Missing unknown attacks (bypass)	False positives and negatives; drift
Test with	Evasion encodings	Malicious traffic to add intrusive specifications

Reproduce from memory before moving on

Table 3.1 — every K3 question in this chapter is a row of it.

Authentication vs authorization and **firewall vs zone vs IDS** — the usual K2s.

Humans are the weakest link — the training K2.

Section 4 — Demo Questions with Answers

*Questions 1–8 are the **official ISTQB CTAL-SEC Sample Exam questions for Chapter 5** — #25 to #32 — with official answers and rationale. LO tags are inferred and match the Exam Structure Table. Questions 9–32 are derived strictly from the syllabus, three per mechanism. Correct options are marked ✔.*

Part A — The 8 official Chapter 5 questions

Q1. OFFICIAL · Sample Exam #25 (2 pts)

You are implementing procedures for evaluating system hardening in an effort to test the system's security effectiveness. What procedure might you follow to ensure the hardening mechanisms put in place are working as expected?

a) Closely monitor various security performance reports and metrics to determine if the correct level of access and authentication is achieved ✔

b) Frequently audit strong authentication to ensure a high level of intrusion protection is maintained at all times

c) Evaluate the hardware components that have been hardened and compare these to other hardened software components to ensure equilibrium is being achieved

d) Enlist a known hacker to conduct an independent assessment of the hardening effectiveness

Correct answer: a | LO: AS-5.1.2 (K3) | Syllabus §5.1.2

Why: (a) — official rationale: **there are security performance reports and metrics available that can be used to determine if you have achieved the right level of hardening.** (b) **strong authentication is just one aspect of hardening**. (c) **equilibrium is not needed. The more critical areas may warrant better hardening.** (d) **there is the danger of the hacker not telling you what is found.** Syllabus §5.1.2: tests should show hardening is **working, applied in the right places and in the right ways**.

Q2. OFFICIAL · Sample Exam #26 (1 pt)

What are key attributes of security authentication of a medium complexity IT system?

a) It verifies that the user has the correct profile and corresponding rights to access limited parts of the system

b) It is key in identifying the amount of system resources the user can utilize

c) It verifies that user entering the system is legitimate ✔

d) It uses common credentials among users to gain entry into the system

Correct answer: c | LO: AS-5.2.1 (K2) | Syllabus §5.2.1

Why: (c) — official rationale: **it verifies that the user is legitimate and authorized**. (a) **is not looking at access rights** (that is authorization). (b) **system resource utilization is not a consideration**. (d) **common credential verification should not be used – each individual should have unique credentials**.

Q3. OFFICIAL · Sample Exam #27 (2 pts)

Typical encryption mechanisms are vulnerable to threats which makes it important to understand their effectiveness at any given time. Identify which of the following you should implement to gain confidence in your encryption mechanisms?

a) Evaluate cryptographic keys to ensure they are at least 256 bits in size

b) Ensure you are applying random algorithms to generate random numbers where possible

c) Develop tests that ensure symmetric encryption is used in the right modes ✔

d) Remove all WEP protocols to see how the system performs

Correct answer: c | LO: AS-5.3.2 (K3) | Syllabus §5.3.2

Why: (c) — official rationale: **correct per the syllabus**. (b) **the random algorithm is easy to crack**. (d) **WEP protocols should be left in place, not removed**. For (a) the official rationale says **"a minimum of 768 bits should be used"**; the syllabus itself says **as of 2015 an RSA key less than 2048 bit is considered insecure**. Either way (a) is not the syllabus test — **assessment that right modes are used in symmetric encryption** is.

Q4. OFFICIAL · Sample Exam #28 (1 pt)

Which is true of the relationship between a firewall and a network zone?

a) Both a network zone and firewall focus on the size of data that is being passed through

b) A network zone communicates through safe protocol options while a firewall ensures those protocols are safe

c) A sub-network can be considered a network zone and a firewall can be traffic monitoring software ✔

d) A network zone blocks malicious traffic from an untrusted zone which the firewall does not filter

Correct answer: c | LO: AS-5.4.1 (K2) | Syllabus §5.4.1

Why: (c) — official rationale: **correct per the syllabus**. (a) **network zones do not focus on size of data**. (b) **network zones are parts of the configuration of the firewall and define the authorized flow of data between networks**. (d) **the firewall blocks the traffic, not the network zone**. Syllabus: **a network zone is an identified sub-network with a defined level of trust**; a network-based firewall is **software that monitors traffic between networks**.

Q5. OFFICIAL · Sample Exam #29 (2 pts)

Which of the following would you apply to most effectively test the abilities of an intrusion detection tool?

a) Develop a series of scenarios based on past experience

b) Use tests that generate malicious traffic to add new intrusive specifications ✔

c) Apply it to situations of known malicious traffic

d) Use it in conjunction with other IDS products when possible

Correct answer: b | LO: AS-5.5.2 (K3) | Syllabus §5.5.2

Why: (b) — official rationale: **these tests can be used to add new intrusive specifications which were formerly considered to be authorized traffic.** (a) and (c) **might be useful, but will not be as effective as B in making sure the tool will work for the future as well as the present**. (d) **is true for the usage, but not for the testing**.

Q6. OFFICIAL · Sample Exam #30 (1 pt)

Which of the following is a main disadvantage to malware scanning tools?

a) They only detect certain levels of malware

b) They can only detect malware that is known to the tool ✔

c) They tend to be overly complex to run

d) They do not provide updating and reporting capabilities

Correct answer: b | LO: AS-5.6.1 (K2) | Syllabus §5.6.1

Why: (b) — official rationale: **the malware tool can only detect malware that it already knows about.** (a) **may be correct depending on the particular focus of the tool, but is not a main disadvantage** (the official text labels this "B"; it refers to option a). (c) **the tools are normally easy to run**. (d) **the tools provide the ability to update themselves with new findings and to produce reports**.

Q7. OFFICIAL · Sample Exam #31 (2 pts)

You need to remove personal identification numbers from a legacy system in order to reduce risk during testing. Part of your data obfuscation plan includes verifying how effectively the data is masked. Which of the following is the most effective approach to use?

a) Manually verify in the database that the data targeted for obfuscation is no longer understandable for logical human interpretation

b) Design a brute force attack on the obfuscated data ✔

c) Substitute the sensitive data with random data of varying string lengths

d) Enlist the development teams to generate a program to stress the database for vulnerabilities

Correct answer: b | LO: AS-5.7.2 (K3) | Syllabus §5.7.2

Why: (b) — official rationale: **a brute force or dictionary attack can be used to see if personal information is still accessible.** (a) **is generally not feasible because of the amount of data and time it would take**. (c) **is more of an anonymizing exercise. Also, the field length might be limited so this may corrupt the data.** (d) **we are not trying to stress test the database itself**.

Q8. OFFICIAL · Sample Exam #32 (1 pt)

What is often considered the weakest link in software security?

a) The lack of a consistent and comprehensive security training plan

b) The effort necessary to maintain document and procedure updates in order to keep up with continuing security threats

c) The behavior of humans ✔

d) The constant advancement in malicious techniques

Correct answer: c | LO: AS-5.8.1 (K2) | Syllabus §5.8.1

Why: (c) — official rationale: **it's the people and their behavior that is the weakest link.** Syllabus §5.8.1: **humans are often the weakest link in the overall security picture.**

Part B — 24 additional syllabus-derived questions

Q9. Derived from syllabus

Why does the syllabus recommend configuring a remote logging server (e.g. rsyslog) as part of system hardening?

a) To speed up log analysis

b) So that if a machine is compromised, the attacker can delete log files only on the compromised machine, not on the remote log server ✔

c) To comply with software licensing policies

d) To remove the need for an IDS

Correct answer: b | LO: AS-5.1.1 (K2) | Syllabus §5.1.1

Why: (b) — verbatim reasoning from §5.1.1.

Q10. Derived from syllabus

A default administrator password left unchanged on a database server is an example of which kind of vulnerability?

a) By design

b) By construction

c) By obsolescence

d) By configuration ✔

Correct answer: d | LO: AS-5.1.1 (K2) | Syllabus §5.1.1

Why: (d). §5.1.1: vulnerabilities come from **design errors (by design)**, **source code defects (by construction)** or **lack of rigor in the configuration (by configuration)**.

Q11. Derived from syllabus

A multi-site retailer has hardened 300 store servers. Management wants evidence that hardening is effective without slowing store operations.

Which set of tests best follows the syllabus?

a) Audit server and database configurations for changed default passwords and unnecessary services and ports; verify component and library versions are not obsolete; run a vulnerability scanner across sites; and check that hardening is not so restrictive that it blocks store work ✔

b) Disable all USB ports and assume compliance

c) Ask store managers to confirm by email that servers are hardened

d) Run a load test on one store server

Correct answer: a | LO: AS-5.1.2 (K3) | Syllabus §5.1.2

Why: (a) combines the syllabus tests — configuration audits (**default passwords**, **unnecessary services and network ports**), **version verification**, a **vulnerability scanner** for **complex multi-site** environments — with the instruction to **test for protections that are too restrictive**.

Q12. Derived from syllabus

A user can log in to an FTP server but can only write to their own dedicated directory. Which mechanism enforces the directory restriction?

a) Authentication

b) Encryption

c) Authorization ✔

d) Obfuscation

Correct answer: c | LO: AS-5.2.1 (K2) | Syllabus §5.2.1

Why: (c) — the syllabus's own example of authorization: **a user is authorized to use an FTP server but only on their dedicated space**.

Q13. Derived from syllabus

Which of the following is listed by the syllabus as an authentication architecture option?

a) Single Sign-On (SSO) ✔

b) Network zones

c) Data masking

d) Virtual patching

Correct answer: a | LO: AS-5.2.1 (K2) | Syllabus §5.2.1

Why: (a). Architectures: **local authentication, server authentication, network authentication, Single Sign-On**. Implementations: weak-password detection, **OTP**, fingerprinting, software certificates, certificates in hard tokens.

Q14. Derived from syllabus

Which test exploits a lack of input filtering to bypass authentication?

a) Trying "123456" as a password

b) Entering ../../ in an FTP path

c) Checking the TLS cipher order

d) Injecting SQL into the login fields to be authenticated without any known login/password ✔

Correct answer: d | LO: AS-5.2.2 (K3) | Syllabus §5.2.2

Why: (d) — §5.2.2. (a) is **brute force/dictionary**; (b) is an **unauthorized URI** test; (c) is an encryption configuration test.

Q15. Derived from syllabus

A web shop's admin console is at /admin and is "hidden" from the menu. Customer accounts use passwords of at least 6 characters. The shop runs a framework version two years old.

Which set of tests best evaluates authentication and authorization effectiveness?

a) Measure response time of /admin

b) Request /admin as an anonymous and as a customer user; run brute force and dictionary attacks starting with "123456", "111111", dates of birth and pet names; test login fields for SQL injection; check whether the old framework has a known exploitable vulnerability leading to privilege escalation ✔

c) Review the marketing copy on the login page

d) Confirm passwords are at least 6 characters long

Correct answer: b | LO: AS-5.2.2 (K3) | Syllabus §5.2.2

Why: (b) applies all four syllabus test types: **unauthorized URL (site address/admin)**, **brute force and dictionary**, **SQL injection**, and **exploiting an unpatched vulnerability** for **privilege escalation**. (d) only re-checks the rule, not its effectiveness.

Q16. Derived from syllabus

What distinguishes asymmetric from symmetric encryption, as described in the syllabus?

a) Asymmetric uses a private and public key; symmetric uses a shared secret key ✔

b) Asymmetric is used only for stored data; symmetric only for communication

c) Asymmetric uses hashing; symmetric uses salting

d) Symmetric encryption is always weaker

Correct answer: a | LO: AS-5.3.1 (K2) | Syllabus §5.3.1

Why: (a) — §5.3.1. Both may protect data **stored** (cyphered passwords, drives) or **in communication** (email, SSL/TLS).

Q17. Derived from syllabus

A code review finds that session tokens are generated using the language's default random() function. Which category of encryption vulnerability does this test address?

a) Design vulnerability

b) Configuration vulnerability

c) Construction vulnerability ✔

d) Ageing vulnerability

Correct answer: c | LO: AS-5.3.2 (K3) | Syllabus §5.3.2

Why: (c) — §5.3.2 lists **code reviews (e.g. to verify that the default function random() is not used to generate random numbers (seed) because the random algorithm is relatively easy to crack)** under **construction vulnerabilities**, with fuzzing, timing attacks and power analysis.

Q18. Derived from syllabus

A tester checks whether an attacker can force the server to negotiate a weaker cipher. Which syllabus test is this?

a) Power analysis

b) Replay attack against WEP

c) Timing attack

d) TLS cipher order on the server side, to see if the cipher can be downgraded or renegotiated ✔

Correct answer: d | LO: AS-5.3.2 (K3) | Syllabus §5.3.2

Why: (d) — a **configuration** vulnerability test in §5.3.2.

Q19. Derived from syllabus

Which zone is considered the most trusted?

a) The Internet / public zone

b) Private / internal networks ✔

c) The DMZ

d) All zones are equally trusted

Correct answer: b | LO: AS-5.4.1 (K2) | Syllabus §5.4.1

Why: (b) — the syllabus: Internet/public **untrusted**; DMZs with **different levels of trust**; private/internal **most trusted**.

Q20. Derived from syllabus

What can a Web Application Firewall filter on that a traditional firewall typically does not, according to the syllabus?

a) TCP/UDP ports

b) Fragmentation and TTL options

c) Users being the connections, and data using pattern descriptions ✔

d) Source and destination IP addresses

Correct answer: c | LO: AS-5.4.1 (K2) | Syllabus §5.4.1

Why: (c). Firewalls filter **addresses and protocols, protocol options, size of data**; WAFs **also** filter **users being the connections** and **data (pattern descriptions)**.

Q21. Derived from syllabus

Which test attempts to bypass firewall filtering so that an attack can be carried out behind the firewall?

a) Fragmentation attacks ✔

b) Port scanning

c) Password auditing

d) EICAR test file

Correct answer: a | LO: AS-5.4.2 (K3) | Syllabus §5.4.2

Why: (a) — §5.4.2: **fragmentation attacks to bypass filtering features with the objective to carry on the attack behind the firewall**. Port scanning verifies **the policy is well implemented**.

Q22. Derived from syllabus

Which statement describes the positive security model for intrusion detection?

a) All that is not explicitly forbidden is allowed

b) Detection is based on a list of known attacks

c) It is also called blacklist detection

d) All that is not explicitly allowed is rejected; detection is based on a specification of the expected behavior of the system ✔

Correct answer: d | LO: AS-5.5.1 (K2) | Syllabus §5.5.1

Why: (d). (a), (b) and (c) describe the **negative** (signature-based, blacklist) model.

Q23. Derived from syllabus

How does an IDS differ from a firewall?

a) An IDS blocks all traffic from untrusted zones

b) A firewall looks outwardly at the traffic to stop intrusions, whereas an IDS analyzes suspicious intrusions and raises an alert if they are confirmed ✔

c) An IDS only works at the network layer

d) A firewall cannot be software

Correct answer: b | LO: AS-5.5.1 (K2) | Syllabus §5.5.1

Why: (b) — §5.5.1. An IDS monitors **all 7 OSI layers**, so (c) is wrong; firewalls can be **host-based software** or network software, so (d) is wrong.

Q24. Derived from syllabus

A signature-based IDS is to be tested for robustness against evasion. Which set of tests fits the syllabus?

a) Port scanning and password cracking

b) Load testing at peak volume

c) Character encoding or modification (white space, end of lines), IP fragmentation and TCP segmentation, encryption and obfuscation, URL encoding ✔

d) Comparing two IDS vendors' marketing claims

Correct answer: c | LO: AS-5.5.2 (K3) | Syllabus §5.5.2

Why: (c) — §5.5.2: **scenario-based detection is easy to bypass because only known attacks are detected**; the listed **evasion techniques** test it.

Q25. Derived from syllabus

What helps anti-malware detect slight variations of known malicious patterns?

a) A heuristic mechanism ✔

b) A larger firewall rule set

c) Data obfuscation

d) Single Sign-On

Correct answer: a | LO: AS-5.6.1 (K2) | Syllabus §5.6.1

Why: (a) — §5.6.1: **a heuristic mechanism often is embedded in anti-malware to identify slight variations of known malicious patterns**.

Q26. Derived from syllabus

How can the effectiveness of an anti-malware product be functionally tested without developing real malicious code?

a) By disabling the product and observing

b) By running a password audit tool

c) By fragmenting IP packets

d) By using the EICAR anti-malware test file ✔

Correct answer: d | LO: AS-5.6.2 (K3) | Syllabus §5.6.2

Why: (d) — §5.6.2.

Q27. Derived from syllabus

An organization plans to roll out a new anti-malware version to all 8,000 desktops and servers over a weekend.

What is the most important test consideration, according to the syllabus?

a) Measure how long a full scan takes

b) Test the implementation on a representative platform before deploying to the entire organization, because anti-malware has falsely quarantined legitimate OS files and shut down organizations' computing capability ✔

c) Disable the heuristic engine to avoid false positives

d) Deploy first and monitor the helpdesk for complaints

Correct answer: b | LO: AS-5.6.2 (K3) | Syllabus §5.6.2

Why: (b) — §5.6.2's explicit warning.

Q28. Derived from syllabus

Why is encryption described as an obfuscation technique "with issues"?

a) It cannot be applied to source code

b) It is too slow for databases

c) The cyphered data remains viewable to those with valid keys ✔

d) It cannot be reversed

Correct answer: c | LO: AS-5.7.1 (K2) | Syllabus §5.7.1

Why: (c) — §5.7.1: **encryption is also an obfuscation technique but with issues because the cyphered data will remain viewable to those with valid keys**.

Q29. Derived from syllabus

To verify that a commercial Java application's code obfuscation protects a proprietary algorithm, which test fits the syllabus?

a) Attempt to reverse-engineer the byte code with a Java decompiler, and attempt brute force against weak obfuscation mechanisms (e.g. unXOR) ✔

b) Encrypt the source repository

c) Run a port scan on the application server

d) Count the lines of obfuscated code

Correct answer: a | LO: AS-5.7.2 (K3) | Syllabus §5.7.2

Why: (a) — §5.7.2 tests to verify obfuscation of code: **reverse-engineering of Java byte code (Java Decompiler) or .NET programs (.NET Reflector)** and **brute force attacks (e.g. unXOR)**.

Q30. Derived from syllabus

After obfuscating a test database, testers discover some records cannot be restored for a reconciliation test. What is the most likely cause, per the syllabus?

a) Obfuscation never allows data to be restored

b) The database was too large

c) Brute force attacks corrupted the data

d) Lack of tight configuration control between the obfuscated data and the keys used, so the wrong key versions were applied ✔

Correct answer: d | LO: AS-5.7.2 (K3) | Syllabus §5.7.2

Why: (d) — §5.7.2: **tight configuration control between the obfuscated data and keys used for the obfuscation is needed to ensure the correct versions of keys are used. Otherwise, the data can not be un-obfuscated for use.**

Q31. Derived from syllabus

Which topics should security training cover, according to the syllabus?

a) Only the password policy

b) The identification of social engineering attacks and insider threats, updated as new policies and threats arise, throughout the lifecycle ✔

c) Only secure coding for developers

d) Only the use of anti-malware tools

Correct answer: b | LO: AS-5.8.1 (K2) | Syllabus §5.8.1

Why: (b) — §5.8.1.

Q32. Derived from syllabus

A security tester injects a SQL command through a data entry field that lacks a field-level edit and views the customer database. The developer had attended secure-coding training last year.

What follow-up best tests and improves training effectiveness?

a) Dismiss the finding because the developer was trained

b) Remove the field from the application

c) Conclude the developer needs additional secure-coding training, and examine other developers' code to see whether the practice is widespread — if so, start a general process improvement initiative ✔

d) Run a password audit on the developer's account

Correct answer: c | LO: AS-5.8.2 (K3) | Syllabus §5.8.2

Why: (c) — the syllabus's second training-effectiveness example in §5.8.2.

Most Important Questions From This Chapter

*Ranking rationale: **four K2 and four K3** drawn from sixteen objectives. In the Sample Exam each mechanism appeared once. Weight your effort evenly, with a slight bias to the K3 (test) side, which is worth double.*

Rank	Topic / question focus	LO	Why it matters
1	IDS models and testing — Q5, Q22–Q24	AS-5.5.x	Most counter-intuitive answer (poison the profile); 2 points if K3.
2	Encryption testing families — Q3, Q16–Q18	AS-5.3.x	Longest test list; design / construction / configuration / ageing.

Rank	Topic / question focus	LO	Why it matters
3	Obfuscation — Q7, Q28–Q30	AS-5.7.x	Brute force and decompilers; key control.
4	Hardening — Q1, Q9–Q11	AS-5.1.x	Audit + scanner + over-restriction.
5	AuthN vs AuthZ — Q2, Q12–Q15	AS-5.2.x	Clean K2 split; four test types.
6	Firewalls and zones — Q4, Q19–Q21	AS-5.4.x	Zone ≠ blocker; port scan / malformed / fragmentation.
7	Anti-malware — Q6, Q25–Q27	AS-5.6.x	Only known; EICAR; representative platform.
8	Training — Q8, Q31, Q32	AS-5.8.x	Humans weakest; three test examples.

Section 5 — Exam Tricks

5.1 Frequently tested topics (evidence-based)

Mechanism	K	Pts	Sample #	Format used officially
Hardening	**K3**	2	#25	Procedure to ensure hardening works → **monitor security reports and metrics**
AuthN/AuthZ	K2	1	#26	Key attribute of authentication → **user is legitimate**
Encryption	**K3**	2	#27	Gain confidence → **symmetric modes test**
Firewall / zones	K2	1	#28	Relationship → **sub-network = zone; firewall = traffic-monitoring software**
IDS	**K3**	2	#29	Most effective test → **malicious traffic to add intrusive specifications**
Anti-malware	K2	1	#30	Main disadvantage → **only known malware**
Obfuscation	**K3**	2	#31	Verify masking → **brute force**
Training	K2	1	#32	Weakest link → **human behavior**
Chapter 5 total	—	**12**	**#25–#32**	**15% of the points from the longest chapter**

The arithmetic

Chapter 5 takes **240 of 1,110 teaching minutes (22%)** but returns **12 of 80 points (15%)** — **3.0 points per hour**, tied lowest with Chapter 9. With **16 objectives for 8 questions**, roughly **half of what you learn here will not be examined on any given paper**. Study the **concept + weakness + test** triple for each mechanism (Table 3.1) and stop there.

5.2 Common distractors observed

- **Authorization described as authentication** (profile, rights, limited parts of the system).
- **Shared credentials** — each individual should have unique credentials.
- **"Random algorithms"** for randomness — the default random() is easy to crack.
- **Key-size numbers** not from the syllabus (256 bits) — the syllabus figure is **RSA ≥ 2048 bits (as of 2015)**.
- **The zone as the blocker** — the **firewall** blocks; zones define authorized flows.
- **Known-scenario testing of an IDS** — useful, but less effective than **malicious traffic that adds new intrusive specifications**.
- **Manual inspection** of masked data — not feasible at volume; **brute force** is the test.
- **Hiring a known hacker** — risk they don't tell you what they found.
- **Equilibrium** of hardening across components — critical areas may warrant more.

5.3 Keyword recognition (map words → answers)

If the stem says...	Think...
"reduce attack surface"	**Hardening**
"default passwords", "unnecessary services and ports"	**Hardening audit**
"who is the user / is it really them"	**Authentication**
"rights to do an action", "level of access"	**Authorization**
"123456", "pet name"	**Brute force / dictionary**
"../../", "/admin"	**Unauthorized URI / URL**

If the stem says...	Think...
“modes”, “key size”, “self-signed”	**Encryption design** tests
“random()”, “timing”, “power”	**Encryption construction** tests
“cipher order”, “downgrade”	**Encryption configuration** test
“DMZ”, “trust level”	**Network zones**
“port scan”, “malformed packets”, “fragmentation”	**Firewall** tests
“blacklist”, “signature”	**Negative** model
“white list”, “behaviour”, “regular expression”	**Positive** model
“EICAR”	**Anti-malware** functional test
“quarantined OS files”	Test anti-malware on a **representative platform** first
“masking”, “anonymization”	**Obfuscation**
“decompiler”, “unXOR”	**Code obfuscation** tests
“sticky notes”, “fake support call”	**Training effectiveness** tests

5.4 Typical traps

- **IDS vs firewall.** Firewall **stops** (looks outward); IDS **alerts** (analyzes suspicious intrusions).
- **Negative vs positive** — the names are counter-intuitive: **negative = blacklist = signatures**.
- **False negative** = an alert that **should have been reported but wasn’t**.
- **Phishing and pharming** are listed as **anti-malware detection targets**.
- **Obfuscation** is used **by attackers** too.
- **Code cannot fully protect itself against de-obfuscation**, because debugging can always be used.
- **Password audit tools** carry a risk — **passwords may be viewable to the tester**.

5.5 How to eliminate wrong answers

1. Identify the **mechanism** in the stem, then the **weakness** the syllabus names for it.
2. Strike options that **don’t test** the mechanism (they configure, buy, or remove it).
3. Strike options that **reduce** coverage of the weakness (remove WEP, disable heuristics).
4. Strike options that introduce **new risk** (hire a hacker, deploy without a pilot).
5. Of the remainder, choose the one using **syllabus test vocabulary**.

5.6 Scenario-solving shortcuts

Scenario shape	Shortcut
“Is hardening working?”	Audit configs + scanner + metrics; also check **over-restriction**
“Is login safe?”	Brute force/dictionary · SQLi · URL/URI · unpatched exploit
“Is encryption strong?”	Design (modes, keys, certs, replay) · construction (code review, fuzzing, timing, power) · configuration (TLS, cipher order) · ageing
“Is the firewall effective?”	Port scan → malformed/fuzzed packets → fragmentation; WAF → encoded payloads
“Is the IDS effective?”	Evasion for signatures; **malicious traffic to extend specifications** for behaviour
“Is anti-malware effective?”	EICAR; representative-platform pilot

Scenario shape	Shortcut
"Is masking effective?"	Brute force/dictionary; decompilers for code
"Did training work?"	Social engineering call · desk sweep · password audit · tester SQLi · physical access

5.7 Common candidate mistakes

- Spending a week here. **Three evenings is enough** for 12 points.
- Bringing outside crypto knowledge into answers — answer **from the syllabus's lists**.
- Forgetting that hardening tests include checking it is **not too restrictive**.
- Assuming the official answer key is always internally consistent — see the Q27 and Q30 notes.

5.8 Mnemonics that carry the whole chapter

Mnemonic	Expands to
"Hard Auth Enc Fire IDS Mal Obf Train" ("**H**ow **A**re **E**very **F**ortress's **I**nner **M**oats **O**ften **T**ested?")	The eight mechanisms in syllabus order
D-C-C + Age	Encryption tests: **D**esign, **C**onstruction, **C**onfiguration, plus ageing
P-M-F ("Please Mind Fragments")	Firewall tests: **P**ort scan, **M**alformed packets/fuzzing, **F**ragmentation
"Negative = Naughty list"	Negative model = blacklist of known attacks
"Who? Really? May I?"	Login (who) · password (really) · authorization (may I)
"Known only"	Anti-malware's main disadvantage

5.9 Chapter 5 mind map

Branch	Leaves
Hardening	Design/construction/configuration · remove, patch, configure, remote logs · mechanisms to use · balance · audits, scanner, static analysis
AuthN/AuthZ	ID + token · OTP, certificates, SSO · rights and levels · brute force, SQLi, URI/URL, exploit
Encryption	Plain/cypher · at rest, in transit · symmetric/asymmetric · hashing, salting · DCC + ageing tests
Firewall	Host/network · zones of trust · filters · WAF · port scan, malformed, fragmentation, encoding
IDS	OSI layers · negative/positive · alerts vs blocks · evasion · false negatives · poisoning test
Anti-malware	Signatures + heuristics · phishing, pharming · evasion techniques · EICAR · pilot
Obfuscation	Masking, anonymization · techniques · encryption caveat · key control · brute force, decompilers
Training	Humans weakest · lifecycle-wide · social engineering, insiders · four effectiveness tests

Section 6 — Flashcards

Cover the back of each card and recall it from the front. All cards are drawn from Chapter 5 of the CTAL-SEC 2016 syllabus. Target: three clean passes before exam day.

FRONT	**1. Is any single security mechanism sufficient?**
BACK	**No — none alone is sufficient in most cases**; each has advantages and disadvantages.
FRONT	**2. Three sources of vulnerabilities (hardening)?**
BACK	**By design · by construction · by configuration.**
FRONT	**3. Define system hardening.**
BACK	**Step-by-step process of reducing the attack surface by applying a security policy and different layers of protection.**
FRONT	**4. Four levels at which hardening applies?**
BACK	**Component · product/application · system · system of systems.**
FRONT	**5. Five hardening removals?**
BACK	Unnecessary **software · libraries and dev tools · accounts/logins · applications and network services · peripherals and hardware ports**.
FRONT	**6. Why a remote log server?**
BACK	An attacker can delete logs **only on the compromised machine**, not on the remote server.
FRONT	**7. Hardening balance warning?**
BACK	Balance with **usability** — at the extreme, **protections are disabled because they block productivity**.
FRONT	**8. Three hardening audits?**
BACK	**Default passwords changed · unnecessary services and ports · components, libraries and versions not obsolete**.
FRONT	**9. Tools for hardening tests?**
BACK	**Vulnerability scanner** (esp. multi-site) · **static analysis / security-oriented analyzers**.
FRONT	**10. Authentication answers which questions?**
BACK	**Login: who is the user? Password: is the user really who he pretends to be?**
FRONT	**11. Authorization purposes?**
BACK	Verify the authenticated user **has rights to an action**; determine **level of access** to resources.
FRONT	**12. Five authentication implementations?**
BACK	**Weak-password detection · OTP · fingerprinting · software certificates · certificates in hard tokens.**
FRONT	**13. Four authentication architectures?**
BACK	**Local · server · network · Single Sign-On.**
FRONT	**14. Most used password (syllabus)?**
BACK	**"123456".**
FRONT	**15. Four authentication/authorization tests?**
BACK	**Brute force and dictionary · SQL injection via unfiltered input · unauthorized URI/URL (../../, /admin) · exploit unpatched vulnerability → privilege escalation.**
FRONT	**16. Define encryption.**
BACK	Encoding **plain text into cypher text** using an **algorithm and secrets** so only authorized persons can decrypt.

FRONT	**17. Symmetric vs asymmetric?**
BACK	Symmetric: **shared secret key**. Asymmetric: **private and public key**.
FRONT	**18. Encryption design tests?**
BACK	**Right modes (symmetric) · key size (RSA < 2048 insecure as of 2015) · certificate validity / self-signed alerts (SSL-trip) · replay (WEP) · protocol attacks.**
FRONT	**19. Encryption construction tests?**
BACK	**Code review (no default random()) · fuzzing · timing attacks · power analysis.**
FRONT	**20. Encryption configuration tests?**
BACK	**TLS configuration assessment · TLS cipher order (downgrade/renegotiation).**
FRONT	**21. Fourth encryption test category?**
BACK	**Ageing** — mechanisms that **have become weak**.
FRONT	**22. Define a firewall (Chapman).**
BACK	**A component or set of components that restricts access between a protected network and the Internet, or between other sets of networks.**
FRONT	**23. Host-based vs network-based firewall?**
BACK	Host: software on **one host** monitoring application I/O. Network: software monitoring traffic **between networks**.
FRONT	**24. Three zone types?**
BACK	**Internet/public (untrusted) · DMZs (varying trust) · private/internal (most trusted).**
FRONT	**25. Firewall filtering criteria?**
BACK	**Addresses and protocols · protocol options (fragmentation, TTL) · size of data.**
FRONT	**26. What else does a WAF filter?**
BACK	**Users being the connections · data via pattern descriptions.**
FRONT	**27. Three firewall tests (+ WAF)?**
BACK	**Port scanning · malformed packets and network fuzzing · fragmentation attacks** (+ WAF: **encode, compress, obfuscate** payloads).
FRONT	**28. Define an IDS.**
BACK	Appliance or application **monitoring activity at all 7 OSI layers** to **detect security-policy violations** and raise alerts.
FRONT	**29. Negative security model?**
BACK	**Signature-based / blacklist**: “all that is not explicitly forbidden is allowed”.
FRONT	**30. Positive security model?**
BACK	**Behavior-based / white list**: “all that is not explicitly allowed is rejected”.
FRONT	**31. IDS vs firewall?**
BACK	Firewall **looks outwardly to stop** intrusions; IDS **analyzes and alerts** on confirmed intrusions.
FRONT	**32. Four IDS evasion tests?**
BACK	**Character encoding/modification · IP fragmentation, TCP segmentation · encryption, obfuscation · URL encoding.**
FRONT	**33. Define a false negative (IDS).**
BACK	**An alert that should have been reported but wasn’t.**

FRONT	**34. Most effective IDS behaviour test?**
BACK	**Use malicious traffic to add new intrusive specifications considered as authorized traffic.**
FRONT	**35. Anti-malware detection targets?**
BACK	**Malware, phishing and pharming.**
FRONT	**36. Main anti-malware strategy and weakness?**
BACK	**Signature-based; cannot detect unknown malware** (heuristics help with variations).
FRONT	**37. Four malware evasion techniques?**
BACK	**System library functions (FindWindow) · string obfuscation (encryption, JS in PDF, UPX) · dynamic loading · automatic updates (Skype Trojan)**; also **GPU** use.
FRONT	**38. Anti-malware functional test file?**
BACK	**EICAR.**
FRONT	**39. Anti-malware deployment rule?**
BACK	**Test on a representative platform first** — false positives have quarantined OS files and shut organizations down.
FRONT	**40. Define data obfuscation.**
BACK	**Making data and source code non-understandable for a human** (data masking / anonymization).
FRONT	**41. Obfuscation protects against…?**
BACK	**Copying (licence bypass)** and **reverse-engineering**.
FRONT	**42. Six obfuscation techniques?**
BACK	**Base64 · XOR · random renaming · method overriding · tab-return-space deletion · shuffling** (+ encryption with the key caveat).
FRONT	**43. Obfuscation tests?**
BACK	Data: **brute force/dictionary**. Code: **Java Decompiler, .NET Reflector, unXOR**.
FRONT	**44. Why key configuration control for obfuscation?**
BACK	Otherwise **data cannot be un-obfuscated** for use.
FRONT	**45. Weakest link in security?**
BACK	**Humans.**
FRONT	**46. What should training cover?**
BACK	**Social engineering attacks and insider threats**, throughout the lifecycle, updated for new policies and threats.
FRONT	**47. Three training-effectiveness tests (passwords)?**
BACK	**Fake tech-support call · sticky notes under keyboards · password audit tools** (risk: tester sees passwords).
FRONT	**48. Developer SQLi finding implies…?**
BACK	**Developer needs training; check others' code; if widespread, process improvement.**

Section 7 — Revision Notes

7.1 One-page chapter summary

Eight layers, none sufficient alone. **Hardening** shrinks the attack surface (remove, patch, configure, log remotely) — test with configuration audits, scanners and static analysis, and check it is not over-restrictive. **Authentication** asks who and whether truly; **authorization** asks what they may do — test with brute force, injection, URL tampering and unpatched exploits. **Encryption** turns plain into cypher text with algorithms and secrets — test design, construction, configuration and ageing.

Firewalls filter between zones of trust; **WAFs** add users and data patterns — test with port scans, malformed packets and fragmentation. **IDS** alert on policy violations via negative (signature) or positive (behaviour) models — test with evasion encodings and with malicious traffic to extend the behavioural specification. **Anti-malware** detects only what it knows — test with EICAR and a representative pilot. **Obfuscation** hides data and code — test with brute force and decompilers. **Training** addresses the weakest link — test with social engineering, desk sweeps and password audits.

7.2 Key definitions to memorize

Term	Definition
System hardening	Step-by-step attack-surface reduction by policy and layers of protection
Authentication	Verifying user identifier and token — who, and really who
Authorization	Rights of the authenticated user; level of access
Encryption	Plain → cypher text with algorithm and secrets
Firewall	Restricts access between a protected network and others
Network zone	Sub-network with a defined level of trust
IDS	Monitors OSI layers to detect policy violations and alert
Data obfuscation	Making data/code non-understandable for humans

7.3 High-priority concepts (study first)

6. Table 3.1 — mechanism → weakness → test (all four K3s).
7. Authentication vs authorization; firewall vs zone vs IDS (common K2s).
8. Negative vs positive IDS models.
9. Encryption test families.
10. Humans weakest link; anti-malware only knows the known.

7.4 Last-minute revision sheet

If you read nothing else

Hardening → audit defaults/services/ports/versions; scanner; static analysis; not too restrictive.

AuthN = legitimate user. AuthZ = rights. Tests: brute force, SQLi, ../../ and /admin, unpatched exploit.

Encryption → **symmetric modes**, RSA ≥ 2048, certificates, replay; no random(); timing/power; TLS cipher order; ageing.

Zone = sub-network with trust level; firewall blocks; WAF filters users and patterns. Tests: port scan, malformed/fuzz, fragmentation.

IDS negative = signature = blacklist; positive = behaviour = white list. Test: evasion; **malicious traffic adds intrusive specs**.

Anti-malware: **known only**; EICAR; pilot on representative platform.

Obfuscation: brute force/dictionary; decompilers; key control.

Training: **humans weakest**; fake support call, sticky notes, password audit.

7.5 Memorization checklist

✓	I can…
☐	explain hardening and list five removals and three audits
☐	separate authentication from authorization and list four tests
☐	list encryption tests under design, construction, configuration and ageing
☐	describe zones, firewall filters, WAF filters and three firewall tests
☐	contrast negative and positive IDS models and name their tests
☐	state anti-malware's weakness, EICAR, and the pilot rule
☐	list obfuscation techniques and tests
☐	give three training-effectiveness tests

7.6 Exam-day quick review

- Expect **one question per mechanism**, alternating K2 and K3.
- **Find the weakness; the test exploits it.**
- Answer encryption key-size questions **from the syllabus (2048-bit RSA)**.